

Security Scan Report

Generated on August 24, 2026 at 10:09 AM

Target: http://localhost:8000

Total findings: 10

HIGH (4)

Title: Missing Strict-Transport-Security header

Detail: The Strict-Transport-Security header is not set in the response.

Recommendation: Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains' to force HTTPS.

Title: Missing Content-Security-Policy header

Detail: The Content-Security-Policy header is not set in the response.

Recommendation: Define a Content-Security-Policy to restrict which sources scripts and resources can load from

Title: Connection failed

Detail: Could not connect to localhost:8000 on port 443: [Errno 8] nodename nor servname provided, or not known

Recommendation: Verify the site is reachable over HTTPS.

Title: Sensitive file exposed: /.env

Detail: Exposed sensitive file: /.env

Recommendation: Block access to the file and, critically, rotate any secrets it may have exposed.

MEDIUM (3)

Title: Missing X-Frame-Options header

Detail: The X-Frame-Options header is not set in the response.

Recommendation: Add 'X-Frame-Options: DENY' to prevent clickjacking.

Title: Missing X-Content-Type-Options header

Detail: The X-Content-Type-Options header is not set in the response.

Recommendation: Add 'X-Content-Type-Options:nosniff' to stop MIME-type sniffing.

Title: Directory listing enabled: /uploads/

Detail: The directory /uploads/ returns a browsable file index, exposing its contents.

Recommendation: Disable directory listing (e.g. 'Options -Indexes' on Apache, or 'autoindex off' on nginx).

LOW (3)

Title: Missing Referrer-Policy header

Detail: The Referrer-Policy header is not set in the response.

Recommendation: Add 'Referrer-Policy:no-referrer-when-downgrade'(or stricter) to limit referrer leakage.

Title: Missing Permissions-Policy header

Detail: The Permissions-Policy header is not set in the response.

Recommendation: Set a Permissions-Policy to restrict access to browser features like camera and geolocation.

Title: Information disclosure via Server header

Detail: The Server header reveals: SimpleHTTP/0.6 Python/3.13.7

Recommendation: Configure the server to suppress or obscure its version in the Server header (e.g. 'ServerTokens Prod' on Apache).